Security for Network Systems Lab 5

1. How does VeriSign verify that a certificate signing request came from the correct entity for their “Secure Site” (non EV) certificates? What are two disadvantages/limitations to using method of validation?

VeriSign confirms that a certificate signing request comes from a legitimate organization by checking several details. It verifies the domain ownership, company registration, and contact information of the applicant. The process ensures that the request is genuinely made by the company controlling that website. This helps prevent fake entities from getting certificates for someone else’s domain. Overall, the goal is to build trust and authenticity on the internet.

2. What are Extended Validation certificates? What are two advantages and disadvantages to using extended validation certificates?

Extended Validation (EV) certificates are a type of SSL certificate that shows verified organization details in the browser’s security section. They require a strict review process to confirm the company’s legal identity and right to use the domain. EV certificates make users feel safer by showing that the website is operated by a legitimate business. However, they are more expensive and take longer to issue compared to normal SSL certificates. Another drawback is that many modern browsers no longer highlight EV details clearly to users.

3. What steps could you take to ensure that you have the correct root certificate for VeriSign in your browser?

To make sure you have the correct VeriSign root certificate, you can check your browser’s trusted certificate list under the Authorities section. Viewing a website’s certificate chain helps confirm that it links back to the proper VeriSign root. Keeping your operating system and browser updated ensures you always have the latest trusted certificates. You can also manually verify fingerprints of the root certificate against VeriSign’s official documentation. These steps help protect against fake or tampered certificates.

4. Compare and contrast the OCSP and CRL approaches for certificate revocation.

OCSP (Online Certificate Status Protocol) and CRL (Certificate Revocation List) are both methods to check if a certificate has been revoked. OCSP queries the certificate authority directly for real-time verification, which is faster and more efficient. In contrast, CRL requires downloading a list of revoked certificates, which may become outdated. OCSP provides up-to-date information but depends on the CA server being available. CRL works offline once downloaded but can delay revocation awareness.

5. What X.509 field does a browser check to determine if a received certificate is allowed to be used for the site that sends it?

A browser checks the Common Name (CN) and the Subject Alternative Name (SAN) fields in an X.509 certificate to ensure it matches the site's domain. If the website's address doesn't match either of these fields, the browser issues a warning. These fields define which domains the certificate is valid for. Matching them ensures users are connecting to the correct and secure site. This protects against impersonation or phishing attempts.

6. Why do certificates have an expiration date if there are other certificate revocation mechanisms (i.e. OCSP and CRL)?

Certificates have expiration dates to limit how long they remain valid and reduce risks if a private key gets compromised. It ensures that organizations must periodically renew and revalidate their identities. Even though revocation systems like OCSP and CRL exist, expiry adds a built-in safety measure. It prevents long-term use of outdated or weak cryptographic keys. This practice keeps the overall security infrastructure up-to-date and reliable.